

Partial Framework		
RA DomainCode	RA Domain	RA ControlCode
A	Access Control	HL.1
B	Third Party Data Processing	HL.2
B		HL.3
B		HL.4
B		HL.5
B		HL.6
C	Asset Management	HL.7
C		HL.8
C		HL.9
C		HL.10
D	Exception Handling	HL.11

RA Control

Does your organization have a formal (documented, approved, published, communicated and implemented) Access Control policy/process to include:

- role based access to all resources (applications, OS, network devices, etc.)
- create custom granular permissions and roles
- unique ID for all individuals
- restrict or remove the use of generic IDs (guest, administrator, root, etc.) and
- prohibition on sharing of IDs?

(Please describe your general rules management in relation to role provisioning, deprovisioning, and recertification, including any specific rules for Sensitive/PII data.)

Is SSO supported? please describe the available options, including which internal applications leverage SSO (are applications used to support Ujjivan supported through SSO?)

Is third party (vendor) access to Ujjivan's data restricted, and if not, why?

Do these processors (vendors) contractually comply with your security standards for data processing?

Do you regularly audit your critical vendors? What is the frequency?

Are all contractors and third parties involved subject to background verification (as allowed by local laws and regulations)

Does your organization have a formal (documented, approved, published, communicated and implemented) asset management program which:

- includes a complete list of all hardware and software assets?
- has an owner responsible for approving and reviewing access to the assets?

Does your asset management program address the treatment, handling, disposal, destruction and reuse of media / assets that contain target data (Ujjivan data) ?

Does your organization have a formal (documented, approved, published, communicated and implemented) information classification policy?

Is the classification of all target data (Ujjivan data) determined; and are data protection controls implemented in accordance with data classification?

Do you have a policy and process for exception?

Question	Weightage
1. Whether an up-to-date inventory of IT assets is maintained?	100
1. Whether an inventory of supporting IT infrastructure and facilities is maintained?	20
1. Whether inventory of information assets including business and customer information is maintained?	20
1. Whether the criticality of your IT assets and supporting infrastructure is defined and recorded?	20
1. Whether the data/information is classified based on defined information classification/sensitivity criteria?	20
1. Whether controls are in place to manage and provide protection of the IT assets within your network?. It shall take into consideration how the data/information is stored, transmitted, processed, accessed and put to use both within/outside the Organization's network and the level of risk they are exposed to depending on the sensitivity of the data/information.	20
1. Whether controls are in place to manage and provide protection of the IT assets outside your network?	25
1. Whether there is an up-to-date inventory of authorised/unauthorised software(s)?	25
1. Whether controls are in place to restrict installation of software/applications on end-user PCs, laptops, workstations, servers, mobile devices?	25
2. Whether controls are in place to prevent installation and running of unauthorised software/applications on such devices/systems?	25
1. Whether controls are in place to continuously monitor the release of patches by third parties i.e. vendors / OEMs, advisories issued by CERT-in and other similar agencies?	100